
TROPIC01

ODN_TR01_app_008

Security Architecture Application Note

Version: 1.1

Abstract

This application note outlines the Threat Model and the layered *Defense-in-Depth* countermeasures protecting sensitive assets against logical, physical, and side-channel attacks. Key topics include Secure Lifecycle management, logical hardening of digital blocks (including ECC Engine), and physical protections such as tamper sensors and the MAC-and-Destroy mechanism [3]. TROPIC01 ECC Engine is internally named SPECT (Secure Processor of Elliptic Curves for Tropic), see [7] for its internal FW.

June 12, 2026





Contents

1	Introduction	4
2	Threat Model	5
2.1	Attacker Model	7
2.2	Attack Surface	9
3	Cryptographic Algorithms and Security Primitives	12
4	Security Architecture and Measures	14
4.1	Process and Transparency	14
4.2	Entropy and Identity	14
4.2.1	True Random Number Generator (TRNG)	14
4.2.2	Physically Unclonable Function (PUF)	15
4.3	Lifecycle and Provisioning	15
4.3.1	Public Key Infrastructure	15
4.3.2	Secure Lifecycle Architecture	15
4.3.3	Lock Bus Mechanism	16
4.4	System and Firmware Security	18
4.4.1	Bootloader	18
4.4.2	Configuration Management	18
4.4.3	Firmware Upgrade	19
4.5	Digital Logic Hardening	19
4.5.1	Finite-State Machine encoding	19
4.5.2	Robust Wired Signals	20
4.5.3	Memory Protection	20
4.5.4	ECC Engine	20
4.6	Physical Security	22
4.6.1	Tamper Sensors and Shields	22
4.6.2	MAC-and-Destroy Mechanism	22
5	Security Reports and Advisories	24



Glossary

- **AES** – Advanced Encryption Standard
- **CA** – Certificate Authority
- **CRL** – Certificate Revocation List
- **CVD** – Coordinated Vulnerability Disclosure
- **ECC** – Elliptic Curve Cryptography (also used for Error Correction Code)
- **ECDH** – Elliptic-curve Diffie–Hellman
- **ECDSA** – Elliptic Curve Digital Signature Algorithm
- **EMP** – Electromagnetic Pulse
- **FI** – Fault Injection
- **FSM** – Finite State Machine
- **FW** – Firmware
- **GDSII** – Graphic Data System II (standard file format for IC layout data)
- **I-Config** – Initialization Configuration (Irreversible)
- **IP** – Intellectual Property (referring to circuit blocks/cores)
- **ISAP** – Inverse Sponge-based Authenticated Protocol
- **LCC** – Life-Cycle Controller
- **MAC** – Message Authentication Code
- **MCU** – Micro-Controller Unit
- **NVM** – Non-Volatile Memory
- **OTP** – One-Time Programmable memory
- **PKI** – Public Key Infrastructure
- **PUF** – Physically Unclonable Function
- **R-Config** – Runtime Configuration (Reversible)



- **RoT** – Root of Trust
- **RTL** – Register Transfer Level
- **SCA** – Side-Channel Analysis
- **SDK** – Software Development Kit
- **SPECT** – Secure Processor of Elliptic Curves for Tropic
- **SPI** – Serial Peripheral Interface
- **TRNG** – True Random Number Generator



1 Introduction

This document is intended for security architects, system integrators, and auditors evaluating TROPIC01's posture for secure embedded systems.

The TROPIC01 is designed to serve as a Root of Trust (RoT) in embedded systems. A Root of Trust is a foundational component whose integrity is assumed, and whose job is to enforce security properties for the rest of the system. Because the TROPIC01 (Target) is isolated from the main application processor (Host), its internal secrets remain secure even if the host firmware is compromised. While a compromised host may attempt to request unauthorized operations, it cannot extract the private key material stored within TROPIC01.

The TROPIC01 provides:

- trusted storage for secrets (keys, seeds, PIN verifiers, credentials, etc.),
- trusted execution of cryptographic operations,
- trusted verification of chip integrity (e.g., verifying firmware signatures).
- NIST800-90b and AIS31 compliant True Random Number Generator

This provides a hardware-enforced anchor for the device's overall security posture.

The full security architecture of TROPIC01 consists of several layers. According to the Threat Model introduced in Section 2, an attacker needs to overcome more of them to compromise the TROPIC01 device.



2 Threat Model

TROPIC01 acts as a cryptographic coprocessor and secure storage unit. It is typically embedded in a hostile environment (e.g., a hardware wallet or IoT device) where we consider the Host MCU potentially compromised or untrusted, and the attacker has physical access to the device.

The device's main microcontroller (Host MCU) interacts directly with the Target, which is the TROPIC01 secure element. These two components communicate via an SPI interface secured by the Noise protocol [12] at the session layer.

Note

The Security Boundary

The security of a system utilizing TROPIC01 relies on the S_{HiPRIV} (Host Static Private Key stored inside the Host MCU) to authenticate the Host via the Noise protocol. If the Host MCU is fully compromised and the S_{HiPRIV} is exfiltrated, an attacker can establish a valid encrypted channel. To mitigate this, the system security architecture must rely on **Defense in Depth**:

1. MCU Protection: Developers must apply best practices on the Host side (e.g., Read-Out Protection, TrustZone/Memory Protection Unit) to protect the S_{HiPRIV} . Furthermore, it is possible to implement multiple S_{HiPRIV} keys within the MCU application and restrict their respective access rights. This granular approach ensures that should the confidentiality of a single key be compromised, the overall impact is minimized and the attacker's lateral movement is restricted.

2. MAC-and-Destroy (PIN/Passcode) (Optional): Sensitive operations can be protected by a 32-byte secret guarded by a PIN. The PIN is verified using the **"MAC-and-Destroy"** mechanism [3], which inherently consumes and destroys a verification slot prior to each attempt. Once the attempt limit is reached, the underlying 32-byte secret is permanently erased, effectively thwarting brute-force attacks. Upon successful verification, the consumed slots are fully restored.



TROPIC01 protects the following assets:

- Master Secrets: Private keys (Ed25519, P-256) and seed materials.
Impact: Critical (Total loss of confidentiality).
- User PIN: The user's authentication secret.
Impact: High (Allows unauthorized use if device is stolen).
- Randomness: Output from the TRNG (True Random Number Generator).
Impact: Critical (Predictable keys resulting in weak crypto).
- Firmware Integrity: The code running on the RISC-V Ibex core [14].
Impact: High (Risk of opening a way to other attacks).
- Device Identity: The unique key and internal PUF-derived secrets.
Impact: Medium (Risk of cloning or spoofing the device).

The main challenges in securing those assets are:

- Side-Channel Analysis (SCA): Attacker monitors power consumption, measures various physical emissions, or performs timing analysis to extract key bits.
- Fault Injection (FI) / Glitching: Attacker introduces voltage spikes, clock glitches, electromagnetic or laser pulses to skip instructions or dump memory.
- Physical Probing / Decapping: Attacker chemically removes the package to probe internal buses or read non-volatile memory directly.
- Man-in-the-Middle (MITM) and Sniffing: Attacker solders probes to the SPI lines to read data or inject malicious commands.
- Replay Attacks: Attacker records a valid command sequence and replays it later.
- Transparent Design Risk: Attackers study the open-source [8] and firmware [9] offline to find zero-day vulnerabilities.
- PIN Brute Force: Attacker tries every possible PIN combination to bypass authentication.
- Counterfeiting: Attacker replaces the chip with a malicious clone that leaks user's secrets.



2.1 Attacker Model

Unlike traditional “black box” secure elements, the TROPIC01 attacker has perfect knowledge of the RTL (Register Transfer Level) design and firmware. The manufacturer does not completely disclose the physical implementation (GDSII); however, the knowledge of the RTL-level for auditability, potentially supports adversary reverse engineering practices as well. Since the RTL is public, attackers can focus entirely on finding logical or physical weaknesses rather than spending effort on reverse-engineering.

We define the Attacker Profile for TROPIC01 below, structured according to Access, Capabilities, and Knowledge.

1. *The “White-Box” Analyst* (Logical Attacker):

This profile is unique to TROPIC01’s open nature. It represents a cryptographer or hardware engineer who studies the publicly available datasheets, RTL code, and firmware of TROPIC01 on GitHub. His goal is to find logical flaws, race conditions, or cryptographic weaknesses without ever touching the physical chip. The attacker has infinite time and does not need any equipment. On the other hand, the TROPIC01’s openness offers auditability and security campaigns run by ethical hackers. Possibly found vulnerabilities will then be reported and solved via Coordinated Vulnerability Disclosure.

2. *The Supply Chain Interdictor* (Pre-Deployment Attacker):

This adversary operates within the manufacturing or design ecosystem, aiming to compromise the device before it reaches the user. A critical threat in this domain is the insertion of hardware Trojans into third-party Intellectual Property (IP) blocks or the silicon die itself. To mitigate this, we enforce validation and qualification protocols.

3. *The Malicious Device Owner* (Lab Attacker):

The well-known “Smart Card” attacker model. They own the device and are willing to compromise it to extract secrets. This attacker profile is the one described in detail later in this section.



Malicious Device Owner Attacker Profile

Access: Unlimited Physical Access. The attacker possesses the device (e.g., a hardware wallet or IoT node) in a controlled lab environment.

Goal: Compromise one or more of the protected assets listed earlier in this Section 2.

Attack techniques: The attacker employs various techniques to subvert the chip's defenses and compromise its assets. An analysis of these methods follows:

- *Fault Attacks:*

In this scenario, an attacker manipulates the device's environment—using voltage spikes, clock glitches, electromagnetic or laser pulses—to induce specific errors. The goal is to force the chip to skip critical instructions (such as a PIN check) or corrupt a sensitive variable, leading to a verification bypass or the leakage of secrets via faulty cryptographic output.

We classify attacker capabilities in the fault-injection (FI) domain according to Karaklajić et al. [19], distinguishing the attacker's ability to control the localization and timing of the injected fault. We consider no, loose, or precise FI controllability over both time and location, forming a matrix of attacker capabilities (see Figure 1). Among these, the Advanced FI Attacker Model is defined as having precise timing combined with at least loose spatial control. This means the attacker can consistently inject a fault into a specific variable (word-level accuracy), or potentially even a specific bit, at an exact point in time.

	No	Loose	Precise
No			
Loose			
Precise			

Figure 1: Attacker capabilities matrix [19] illustrating the Advanced FI Attacker profile.

TROPIC01's Fault Injection measures were implemented in a best-effort manner to achieve the highest possible FI resilience given the available technology and design-time constraints. Supported by external validations, the assessed FI resilience of the TROPIC01 ACAB chip corresponds to the loose timing and precise localization attacker profile (see Figure 2). The chip's limited resilience against the Advanced FI Attacker is bound by physical sensor sensitivity limits and the current baseline firmware hardening. However, successfully evading these sensors



still demands highly precise attack localization and meticulous laser parameter tuning.

	No	Loose	Precise	
No				Location
Loose				
Precise				
	Timing			

Figure 2: Attacker capabilities matrix [19] illustrating the assessed FI resilience profile of the ACAB chip.

■ *Side-Channel Analysis:*

An attacker measures power consumption (DPA/SPA), electromagnetic emissions (EMA), or performs timing analysis while the chip executes encryption or other secret-dependent operations. TROPIC01 uses 1. ISAP protocol [13] (designed for side-channel resistance), 2. various masking schemes and 3. constant-time (hiding) cryptographic algorithms. The implementation of 4. clock jitter and clock stealing introduces temporal misalignment in power traces, forcing attackers to use advanced resynchronization techniques and exponentially increasing the effort required for a successful Side-Channel Analysis (SCA).

2.2 Attack Surface

Rather than addressing package-level invasive attacks (e.g., FIB or decapsulation), the following section prioritizes block-level threat modeling. We analyze vulnerabilities specific to the individual internal subsystems of TROPIC01 shown in the following block diagram.

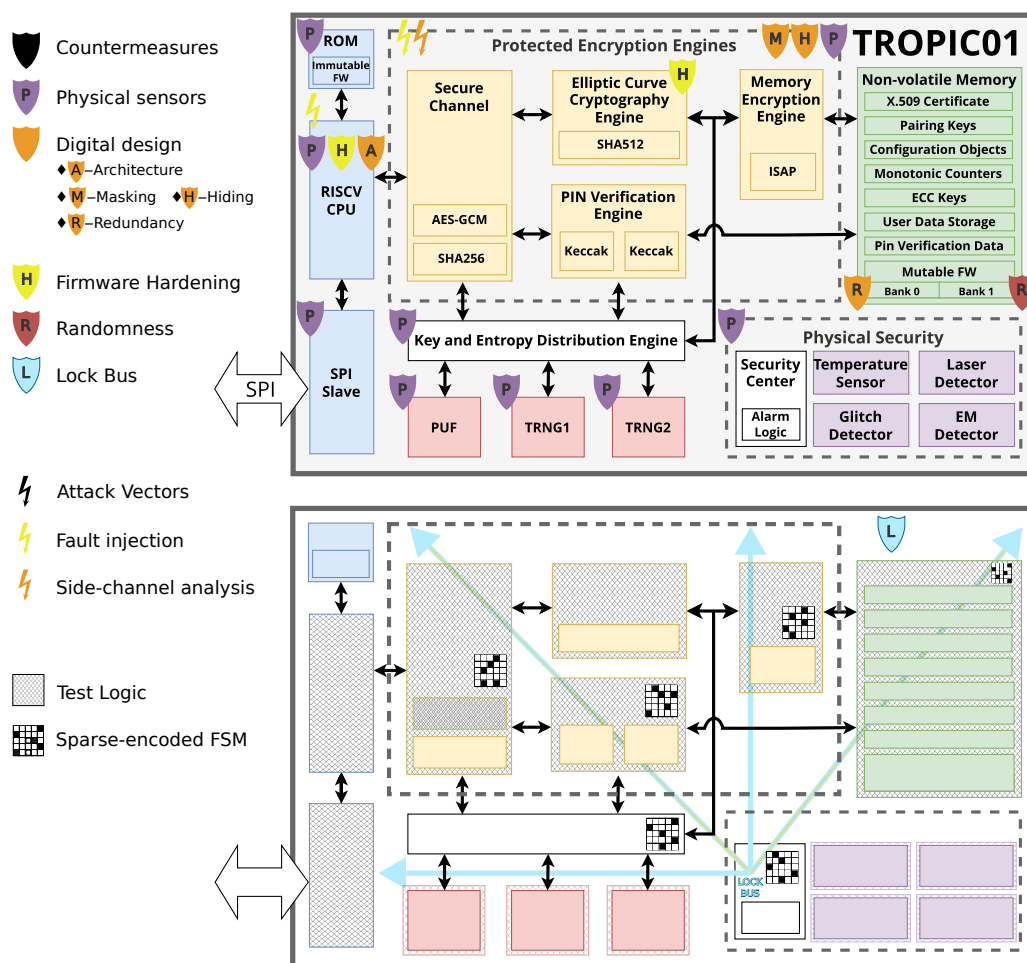


Figure 3: TROPIC01 attack surface and main countermeasures

There are several higher-level security measures shown in the diagram:

- **Test Logic Isolation:** Because the test logic grants privileged access to the digital blocks of TROPIC01 – an essential feature for manufacturing validation – it also represents a potential vector for extracting secrets. To mitigate this risk, the design explicitly excludes security-critical areas from scan chains. Instead, engineers validate these blocks solely through functional testing, ensuring no debug path exists to sensitive data.
- **Lifecycle Management:** To prevent unauthorized re-enabling of debug features or state rollbacks, the device utilizes a hardened *Life-Cycle Controller* and a redundant *Lock Bus*. These mechanisms enforce the irreversible transition from the **Virgin** (factory) state to the **Provisioned** (user) state. Detailed architecture of these blocks is provided in Section 4.3.2.



- **Control Flow Integrity:** To counter fault injection attacks aimed at corrupting logic states, all security-critical controllers utilize *Sparse-encoded Finite State Machines (FSMs)*. This encoding ensures that glitch-induced invalid states trigger immediate security alarms rather than unintended behavior.

Moving from global defenses to the block level, a diverse array of targeted countermeasures fortifies individual functional units:

- Physical tamper sensors and an active shield protect all digital blocks (except non-volatile memory blocks).
- Error Correction Code (ECC) logic fortifies Flash memory, OTP memory, and RISC-V RAM (all on-chip memories excluding ECC Engine internal memories, which are secured by specific hardware hardening) to ensure data integrity. On-the-fly encryption and physical address scrambling secure the data against physical analysis. Physically Unclonable Function (PUF) block derives the scrambling patterns, uniquely binding the memory layout to the specific silicon instance, while internal True Random Number Generator (TRNG) block dynamically generates the encryption keys.
- The encryption engines (ECC Engine, AES-GCM [18] [17] and ISAP Engine [13]) implement various masking and hiding techniques to defend against side-channel analysis (SCA). Additionally, they employ hardware fault detection logic, data redundancy, and cryptographic verification steps to thwart fault injection attacks.
- The device utilizes a RISC-V Ibex core, hardened against fault injection through a Dual-Core Lockstep system [14]. This mechanism runs two redundant cores in parallel and compares their outputs cycle-by-cycle to detect anomalies.
- The firmware modules for both the RISC-V core and the ECC Engine are explicitly hardened. They feature countermeasures against fault injection (such as instruction skipping) and employ constant-time algorithms to ensure resistance against timing-based side-channel attacks.



3 Cryptographic Algorithms and Security Primitives

The TROPIC01 secure element integrates a set of modern cryptographic algorithms designed to establish robust device identity, ensure secure key storage, and execute protected operations. Its architecture strictly isolates critical operations: the dedicated ECC Engine handles high-performance cryptographic computations, while specialized peripheral blocks manage supporting functions—such as entropy generation and secure messaging. The following section details the primary cryptographic primitives utilized within TROPIC01 and maps them to their specific internal execution units.

1. Elliptic Curve Cryptography (ECC)

- P-256 (ECDSA) — used for signing users' data and transactions
- Ed25519 (EdDSA) — used for signing
- Elliptic-curve Diffie-Hellman (ECDH / X25519) — used for key agreement / key exchange

2. Symmetric Encryption

- AES-256 GCM — for secure channel encryption + authentication

3. Hash / Message Authentication

- Keccak — used in several contexts for its SCA resistance
- MAC-and-Destroy scheme based on Keccak for PIN verification

4. Secure Messaging (Noise Protocol [12])

- Encrypted and authenticated channel with “strong forward secrecy”

5. Random Number Generation

- TROPIC01 has two TRNGs, each compliant with NIST SP800-90B and AIS31.

6. Physically Unclonable Function (PUF)

- A 256-bit per-chip PUF is used — provides a unique chip fingerprint used for internal encryption.



Security implications of these primitives:

- *Strong Asymmetric Security:* Using P-256 and Ed25519 gives a good balance of performance and security.
- *Authenticated Encryption:* AES-GCM ensures that both confidentiality and integrity are protected when exchanging data or storing sensitive data.
- *Secure Key Exchange:* ECC-based ECDH (or X25519) enables secure session key establishment, which is critical for “secure channel + forward secrecy.”
- *High-Quality Randomness:* TROPIC01 features two independent TRNGs to ensure strong entropy. One dedicated instance provides internal randomness for generating critical cryptographic keys and countermeasures, while the second instance is strictly isolated to serve user-demanded randomness. This separation prevents entropy exhaustion and makes the system highly resistant to attacks that exploit weak or predictable randomness.
- *Unique Hardware Identity:* The PUF helps tie cryptographic keys to the physical hardware, which helps prevent cloning or duplication of devices and template attacks.



4 Security Architecture and Measures

The security of TROPIC01 does not rely on a single fortress wall; instead, it employs a layered *Defense-in-Depth* architecture. This approach ensures that if an attacker compromises one layer – whether through mathematical cryptanalysis, logical fault injection, or invasive physical probing – subsequent layers remain intact to protect the chip’s secrets. In this section, we detail these defenses, categorizing them by their abstraction level: from the organizational transparency and lifecycle provisioning down to the logical hardening of digital blocks and the physical sensors protecting the silicon die.

4.1 Process and Transparency

Security extends beyond hardware architecture; it relies on openness to enable independent auditability. To support this transparency, we employ an overarching process for Coordinated Vulnerability Disclosure (CVD). By establishing clear channels for ethical hackers to report vulnerabilities, we ensure that issues are remediated before being publicly disclosed alongside their solutions.

4.2 Entropy and Identity

At the core of TROPIC01’s security architecture lie two fundamental hardware primitives that bridge the analog and digital worlds: the True Random Number Generator (TRNG) and the Physically Unclonable Function (PUF). Together, they provide the essential ingredients for a Root of Trust: high-quality entropy for dynamic operations and a unique, unforgeable silicon fingerprint for static identity.

4.2.1 True Random Number Generator (TRNG)

Cryptographic security relies heavily on unpredictability. TROPIC01 integrates two independent TRNGs, compliant with NIST SP 800-90B and AIS-31 standards. These blocks generate high-entropy bitstreams, which is critical for:

- Seeding the deterministic random number generators.
- Generating ephemeral session keys for secure channels (Noise, ECDH).
- Providing mask values for side-channel protection in the ECC Engine.



4.2.2 Physically Unclonable Function (PUF)

While the TRNG provides dynamic randomness, the PUF provides static uniqueness. It exploits microscopic, uncontrollable variations in the silicon manufacturing process to derive a device-unique 256-bit key. This “silicon fingerprint” is generated on-demand and is never stored in non-volatile memory (NVM), protecting it from offline extraction attacks. The PUF output is primarily used to seed the memory address scrambling logic and to derive the root wrapping keys for the secure storage hierarchy.

4.3 Lifecycle and Provisioning

This section addresses the critical transition from a generic, open silicon die to a secured, unique trust anchor. It covers the mechanisms used to establish the device’s immutable identity through a robust Public Key Infrastructure (PKI) and details the hardware-enforced lifecycle management that permanently locks interfaces used for initial configuration. Together, these processes ensure that every TROPIC01 chip enters the field as a unique and authenticated unit. Further information is provided in Functional Specification [10].

4.3.1 Public Key Infrastructure

TROPIC01 chips contain a unique serial number and a set of X.509 certificates. These are stored immutably on the device inside OTP memory, which is protected by Error Correction Code (ECC) logic. These certificates form a four-level PKI chain managed by Tropic Square:

1. Tropic Square root CA certificate
2. TROPIC01 “product level” CA certificate
3. TROPIC01 part number (group) CA certificate
4. TROPIC01 chip (device) certificate

Manufacturers use this chain to verify chip authenticity, check revocation status, and bind the chip to the host system during production. The document also describes how to read and validate certificates and CRLs using provided tools and examples [4].

4.3.2 Secure Lifecycle Architecture

The Security Center in the TROPIC01 secure element is a dedicated subsystem responsible for enforcing security policies, monitoring operations, and coordinating secure functionality across the device. It acts as the central authority for access control, anti-tampering, and secure lifecycle management.



One of the major challenges in hardware security is reliably disabling an IC's test and debug features. During manufacturing test, extended access is needed to run diagnostics and measurements. While essential for design and manufacturing, these capabilities directly conflict with the security requirements of the final device.

To resolve this conflict, the primary role of the Security Center is to manage the transition between the silicon life-cycle states:

1. **Virgin** state: the test and debug features are unlocked. It is the default state after the IC is manufactured.
2. **Provisioned** state: the test and debug features are locked. The IC is tested, **Provisioned**, and so ready to be used in the application before the transition into **Provisioned** state is done.

A reliable, one-way mechanism to transition from **Virgin** to **Provisioned** is necessary to satisfy both manufacturing testability and end-user security. This is achieved through the **Life-Cycle Controller (LCC)** and the **Lock Bus**.

Life-Cycle Controller (LCC)

The LCC is implemented as a hardened hardware block to prevent invasive attacks. It consists of two logically isolated components sharing only NVM inputs:

1. **LCC FSM (Finite State Machine):** Controls the NVM read procedure, validates the state (raising an alarm if invalid), determines the silicon life-cycle state, and periodically re-evaluates eFuses.
2. **Lock Bus Encode Circuit:** Drives the physical signals described below. Its output depends solely on NVM inputs and is independent of the internal state of the LCC FSM.

4.3.3 Lock Bus Mechanism

The Secure Locking mechanism has two parts:

1. Locking: Transition from **Virgin** to **Provisioned** state performed during manufacturing in a secure environment.
2. State Read-out: Upon every power-up, the IC must decide which silicon life-cycle state it is in. The IC performs this check in an insecure environment (the field) and is subject to a possible attack.



The state read-out part then is as follows:

- The reset state is always **Provisioned**.
- The Life-Cycle Controller reads the silicon life-cycle state from NVM. The state value is stored redundantly in two different blocks: 1. Anti-fuse One-Time Programmable (OTP) memory, where an all-ones pattern represents the **Virgin** state; 2. Optically readable eFuses, where an all-zeros pattern represents the **Virgin** state. A single specific value representing the **Provisioned** state is programmed into both blocks (OTP and eFuses).
- If the read value represents the **Virgin** state, the Lock Bus encode circuit drives a specific pattern onto a dedicated, system-wide multiple-bit signal. This signal unlocks the test features of the rest of the IC. We refer to this signal as the Lock Bus.
- If the read value represents the **Provisioned** state, the circuit drives a value representing the **Provisioned** state onto the Lock Bus.
- If there is any inconsistency between the data stored in OTP and eFuses, the Lock Bus remains locked and the LCC triggers a security alarm.

Further details on the Lock Bus and Life-Cycle Controller architecture are available online [11] and in Functional Specification [10], Section 19.1.

The attacker might also target the Lock Bus itself, forcing its value to the **Virgin** (assumed to be public or accessible with relatively low effort). Accordingly, the following measures are taken regarding the Lock Bus:

- **Width:** The bus is 32 bits wide, making single-point probing or forcing impractical.
- **Encoding:** The reset value is distinct from the **Virgin** value. The **Virgin** state is represented by a single, unique 32-bit value. All other possible values represent the **Provisioned** state, with a single value used once the LCC has completed the life-cycle state readout.
- **Hamming Distance:** The specific value chosen for **Virgin** has the maximum possible Hamming distance (ideally bit-wise inverse) from the **Provisioned** value, ensuring that voltage glitches cannot easily flip the state.



4.4 System and Firmware Security

To bridge the gap between immutable hardware defenses and flexible user applications, TROPIC01 relies on a strictly controlled system architecture. This layer is responsible for establishing the initial Root of Trust upon power-up, managing persistent device configuration, and ensuring that any changes to the executable code are authenticated and authorized. The following subsections detail the components that maintain this trusted environment throughout the device's operational life.

4.4.1 Bootloader

The bootloader in TROPIC01 is secure, immutable firmware stored in Mask ROM, responsible for initializing the device and establishing a trusted execution environment. Its primary goals are:

- Ensuring that only authentic and integrity-verified firmware is executed.
- Acting as the first step in the device's root-of-trust chain.
- Providing a controlled mechanism for secure firmware updates.

4.4.2 Configuration Management

TROPIC01 manages device behavior through two distinct configuration objects that share an identical structure. Both objects store enable/disable values for security sensors, access privileges, and other system parameters. Detailed structure and update procedures for **CONFIG** objects are defined in the Configuration Objects Application Note [5]. **CONFIG** objects are stored in anti-fuse technology One-Time Programmable (OTP) memory and Flash memory, respectively. To determine the active configuration, the device logically ANDs the values from both sources. Since the default manufacturing value in OTP is '1', this mechanism allows the system to balance immutable hardware constraints with flexible runtime policies:

- **I-CONFIG (Irreversible Configuration):** Stored in OTP. Clearing a bit here is irreversible, effectively permanently enabling a security sensor or restricting an access privilege for the rest of the device's lifetime.
- **R-CONFIG (Reversible Configuration):** Stored in Flash. While it uses the exact same bit layout as I-CONFIG, the values in Flash can be modified (both 0 ↔ 1) to adapt security policies during the device's operational life.



4.4.3 Firmware Upgrade

The FW Update Application Note [6] describes the firmware upgrade process in detail. The document covers:

- The firmware update flow (bootloader vs application firmware)
- Safety measures, like signature verification and version checks (rollback protection), to prevent unauthorized or malicious updates
- How to use SDK (libtropic [2]) to perform updates via a host MCU
- Recovery mechanisms in case an update fails

4.5 Digital Logic Hardening

This section details the micro-architectural countermeasures integrated directly into the digital logic of TROPIC01. While the previous layers enforce high-level security policies, these hardware mechanisms protect the execution flow and data integrity against active physical attacks. The design ensures that fault injection attempts trigger alarms and that sensitive data remains protected against side-channel analysis by utilizing:

1. Sparse Encodings
2. Redundant Signaling
3. Cryptographic Randomization

4.5.1 Finite-State Machine encoding

To mitigate fault-injection attacks that attempt to corrupt control flow, TROPIC01 implements sparse Finite-State Machine (FSM) encoding across all security-critical controllers. Each FSM uses a state encoding scheme in which the Hamming distance between any two valid states is intentionally large ($|H| \geq 4$). This ensures that a single-bit or small multi-bit glitch cannot transform one valid state into another meaningful one. Consequently, if the controller register enters an invalid state, a security alarm is triggered. This approach prevents an attacker from observing faulty/modified sensitive outputs after steering control logic into privileged or unintended states through glitching, voltage manipulation, electromagnetic pulses, or similar fault-inducing methods.



4.5.2 Robust Wired Signals

The chip design identifies several categories of control-critical signals—such as inter-module handshakes, arbitration controls, life-cycle indicators, and security alert lines—that must remain correct even under active fault injection attempts. Therefore, the design does not transmit these signals as single wires, but instead uses robust multi-bit encodings.

The system continuously checks all encoded control signals for validity and internal consistency. If a pattern does not match one of the allowed encodings, or if redundant rails diverge, the system treats the signal as corrupted. On detection of such condition, the system triggers an alarm.

By hardening these wired signals against transient faults and active manipulation, the design ensures that an attacker cannot force unauthorized state transitions, bypass arbitration, falsify a handshake, or suppress or forge security alerts easily.

4.5.3 Memory Protection

TROPIC01 uses a hardware memory-address scrambling to randomize the mapping between logical and physical memory locations. A device-unique scrambling key—derived from on-chip randomness (PUF)—initializes the permutation so that each TROPIC01 device has a different physical memory layout. This countermeasure complicates invasive attacks such as micro-probing or targeted fault injection, since the attacker cannot predict where sensitive data is physically stored. It also improves anti-cloning resilience, as copying raw memory contents to another chip will not reproduce the correct layout.

TROPIC01 integrates ISAP [13] to provide low-overhead, fault-resilient authenticated encryption directly in hardware. The ISAP Engine encrypts and authenticates data as it moves through the device, without needing to store intermediate plaintext in memory. This minimizes exposure of sensitive material, strengthens resistance against side-channel and fault-injection attacks, and ensures that cryptographic operations remain lightweight and robust even in constrained environments. Moreover, Error Correction Code (ECC) safeguards stored data against bit corruption, including faults induced by attacks. Upon detecting a memory error, the mechanism triggers a security alarm.

4.5.4 ECC Engine

To compute asymmetric cryptographic algorithms, TROPIC01 uses a dedicated internal engine – ECC Engine. By isolating these sensitive calculations from the main RISC-V application core, ECC Engine reduces the attack surface and ensures that critical keys are processed within a hardened boundary. ECC Engine implements a dual-layer defense strategy combining silicon-level hardening with robust algorithmic countermeasures.



4.5.4.1 Hardware Hardening The physical design of the ECC Engine core includes features to lower the signal-to-noise ratio for attackers and prevent data remnants:

- **Register Precharging:** The hardware precharges critical registers – including flags, ALU inputs, and bus buffers for keys and randomness – with random “rubbish” values before valid data is loaded. This prevents data-dependent power signatures during register overwrites (Hamming distance leakage).
- **Active Noise Generation:** The ALU is utilized to generate algorithmic noise during critical but non-computational cycles (e.g., during CSWAP or J-Type instructions), flattening the power profile.
- **General Purpose Registers Scrambling:** The Register File addresses are obfuscated using a random XOR mask, preventing localized probing of specific registers.
- **Deterministic Execution:** All internal instructions execute in constant time.

Note

Operations dependent on external asynchronous blocks, such as TRNG or Flash, naturally await handshake signals.

4.5.4.2 Algorithmic and Firmware Hardening While the hardware security features of TROPIC01 are immutable, algorithmic and firmware countermeasures are continuously refined. The techniques described in this section represent the baseline architectural capabilities for the ECC engine; however, customers should consult the latest Firmware Release Notes for the specific hardening mechanisms implemented.

- **Key Splitting:** The engine never stores or uses private keys in plain form. Instead, it maintains them using additive splitting ($d = d_1 + d_2$) and re-masks them with a fresh random value r for every operation ($d'_1 = d_1 - r$, $d'_2 = d_2 + r$).
- **Exception-Free Math:** Elliptic curve operations use complete, exception-free addition formulas [15] and CSWAP-based Montgomery Ladders [16] to ensure maximum execution uniformity and prevent corner-case attacks.
- **Advanced Randomization:** To resist Side-Channel Analysis (SCA), the engine employs:
 - *Coordinate Randomization:* The arithmetic unit randomizes projective coordinates (rx, ry, rz).
 - *Group Scalar Randomization:* The logic blinds scalars ($k' = k + r \cdot \#E$).



- *Point Splitting*: The system splits the base point P into $P_1 + P_2$ for independent multiplication.

- **Fault Injection Defenses:**

- *Invariant Checks*: The engine verifies the integrity of the Montgomery Ladder by checking the invariant $Q_1 - Q_0 = P$.
- *Result Validation*: The engine validates final results against the curve equation before output.
- *Verify-after-Sign*: The engine verifies all outgoing signatures using the public key before releasing them to the host.

4.6 Physical Security

While cryptographic and logical layers protect against data analysis and exploitation, they rely on the underlying hardware behaving correctly. An attacker with physical access may attempt to violate this assumption by subjecting the chip to extreme conditions (fault injection) or by directly probing internal circuits (invasive analysis). TROPIC01 counters these threats with a suite of environmental sensors and physical barriers designed to detect tampering and trigger immediate protective responses. An overview of physical security blocks follows.

4.6.1 Tamper Sensors and Shields

- Voltage-glitch detector to protect against supply-fault injection.
- Temperature sensor to detect abnormal thermal conditions.
- Electromagnetic-pulse (EMP) detector for protection against high-energy EM or laser attacks.
- Light/laser sensor to detect physical inspection attempts.
- Active shield (guard rings / mesh) to detect probing or tampering.
- Passive metal shield layers to reduce electromagnetic leakage.

4.6.2 MAC-and-Destroy Mechanism

The TROPIC01 employs an atomic *MAC-and-Destroy* protocol for PIN verification, designed to thwart brute-force and “tear” (power-interruption) attacks. Unlike traditional comparators, this mechanism does not simply check the PIN against a stored reference. Instead, it operates in three atomic steps:



1. **Destroy:** The mechanism inherently destroys (erases) the content of the PIN verification slot at the start of the process.
2. **MAC:** The device computes a Keccak-based Message Authentication Code (MAC) using the input PIN as key material. The scheme (executing the “Destroy” step first) inherently protects against side-channel attacks by minimizing attacker controllability. Furthermore, the underlying Keccak engine is hardware-hardened against side-channel leakage.
3. **Restore:** The mechanism restores all the verification slots with the secret only if the computed MAC matches the stored reference.

This “destroy-first” approach ensures that any interruption – whether accidental power loss or intentional fault injection intended to bypass the verification logic – results in a failed attempt, irreversibly consuming a retry opportunity. Detailed implementation and usage are described in the PIN Verification Application Note [3].



5 Security Reports and Advisories

A fundamental pillar of our security architecture is transparency and independent auditability. We are convinced that "security through obscurity" is an insufficient approach in modern hardware design. To support this, we maintain publicly available and regularly updated resources for our partners, auditors, and the broader security research community:

- **Security Advisories (SA):** We publish these documents proactively upon the discovery and confirmation of a security vulnerability, in line with our Coordinated Vulnerability Disclosure (CVD) policy. Each advisory provides a detailed threat description, a list of affected products, an overall risk assessment (CVSS), and, crucially, specific actionable recommendations to effectively mitigate the exploit across both current and future silicon revisions.

See Tropic Square Security Advisories.

- **Security Reports (SR):** These reports detail the results of dedicated security evaluations. They offer comprehensive assessments of individual TROPIC01 security components and cryptographic primitives, backed by testing performed in certified external laboratories as well as through our rigorous in-house evaluations. These reports objectively demonstrate the real-world robustness and reliability of the implemented hardware countermeasures.

See Tropic Square Security Reports.



Version history

Version	Date	Description
1.0	10.04.2026	Initial public release
1.1	12.06.2026	ACAB revision FI resilience update

References

- [1] ODD_TR01_datasheet, TROPIC01 Datasheet, Tropic Square,
<https://github.com/tropicsquare/tropic01/tree/main/doc/datasheet>
- [2] TROPIC01 SDK – libtropic,
GitHub: <https://github.com/tropicsquare/libtropic>
Documentation: <https://tropicsquare.github.io/libtropic/>
- [3] ODN_TR01_app_002 – PIN Verification Application Note,
Tropic Square,
https://github.com/tropicsquare/tropic01/tree/main/doc/application_notes
- [4] ODN_TR01_app_003 – PKI Application Note,
Tropic Square,
https://github.com/tropicsquare/tropic01/tree/main/doc/application_notes
- [5] ODN_TR01_app_006 – Configuration Objects Application Note,
Tropic Square,
https://github.com/tropicsquare/tropic01/tree/main/doc/application_notes
- [6] ODN_TR01_app_007 – FW Update Application Note,
Tropic Square,
https://github.com/tropicsquare/tropic01/tree/main/doc/application_notes
- [7] TS SPECT Firmware,
Tropic Square,
<https://github.com/tropicsquare/ts-spect-fw>
- [8] TROPIC01 RTL,
Tropic Square,
<https://github.com/tropicsquare/tropic01-rtl>



-
- [9] TROPIC01 Application Firmware,
Tropic Square,
<https://github.com/tropicsquare/ts-tr01-app>
- [10] ODS_TR01_func – TROPIC01 Functional Specification,
Tropic Square,
https://github.com/tropicsquare/tropic01-rtl/blob/public/doc/chip_top/ODS_TR01_func.pdf
- [11] Hardware Security Countermeasures – Locking,
ORSHIN Project (Open-source ReSilient Hardware and software for Internet of thiNGs),
<https://github.com/ORSHIN/public-assets/blob/public/design-implementation/hardware-security-countermeasures/LOCKING.md>
- [12] Noise Protocol Framework,
Trevor Perrin (Editor),
<https://noiseprotocol.org/noise.html>
- [13] ISAP v2.0 – Submission to NIST Lightweight Cryptography Standardization,
C. Dobraunig, M. Eichlseder, S. Mangard, F. Mendel, B. Mennink, R. Primas, T. Unterluggauer,
<https://csrc.nist.gov/CSRC/media/Projects/lightweight-cryptography/documents/finalist-round/updated-spec-doc/isap-spec-final.pdf>
- [14] Ibex RISC-V Core,
lowRISC,
<https://github.com/lowRISC/ibex>
- [15] Complete addition formulas for prime order elliptic curves,
Joost Renes, Craig Costello, and Lejla Batina,
IACR Cryptology ePrint Archive, Report 2015/1060,
<https://eprint.iacr.org/2015/1060.pdf>
- [16] Montgomery curves and the Montgomery ladder,
Daniel J. Bernstein and Tanja Lange,
IACR Cryptology ePrint Archive, Report 2017/293,
<https://eprint.iacr.org/2017/293>
- [17] On Masked Galois-Field Multiplication for Authenticated Encryption Resistant to Side Channel Analysis,
Hirokazu Oshida, Rei Ueno, Naofumi Homma, and Takafumi Aoki,



Constructive Side-Channel Analysis and Secure Design (COSADE 2018), pp. 44–57,
https://doi.org/10.1007/978-3-319-89641-0_3

- [18] Domain-Oriented Masking: Compact Masked Hardware Implementations with Arbitrary Protection Order,
Hannes Gross, Stefan Mangard, and Thomas Korak,
IACR Cryptology ePrint Archive, Report 2016/486,
<https://eprint.iacr.org/2016/486.pdf>
- [19] Hardware Designer’s Guide to Fault Attacks,
Duško Karaklajić, Jörn-Marc Schmidt, and Ingrid Verbauwhede,
IEEE Transactions on Very Large Scale Integration (VLSI) Systems, 2013,
<https://doi.org/10.1109/TVLSI.2012.2231707>



Legal Notice

Our mission is to provide you with high quality, safe, and transparent products, but to be able to do so, we also have to make the following disclaimers.

To verify the characteristics of our products, consult the repositories we make available on our GitHub. While we do our best to keep the content of these repositories updated, we cannot guarantee that the content of these repositories will always identically correspond to our products. For example, there may be delays in publication or differences in the nature of the software solutions as published and as included in the hardware products. Some parts of our products cannot be published due to third party rights.

We take pride in publishing under open-source license terms, but do not grant licenses to any of our patents. Please consult the license agreement in the repository. We reserve the right to make changes, corrections, enhancements, modifications, and improvements to our products, published solutions and terms at any time without notice.

Since we cannot predict what purposes you may use our products for, we make no warranty, representation, or guarantee, whether implied or explicit, regarding the suitability of our products for any particular purpose.

To the maximum extent permitted by applicable law, we disclaim any liability for any direct, indirect, special, incidental, consequential, punitive, or any other damages and costs including but not limited to loss of profit, revenue, savings, anticipated savings, business opportunity, data, or goodwill regardless of whether such losses are foreseeable or not, incurred by you when using our products. Further, we disclaim any liability arising out of use of our products contrary to their user manual or our terms, their use/implementation in unsuitable environments or ways, or for such use which may infringe third party rights. Notwithstanding the above, the maximum liability from the use of our products shall be limited to the amount paid by you as their purchase price.